

Cloud & Security MCQs

1. What is the primary security advantage of using a public cloud provider?

- a) Reduced cost
- b) Increased physical security and expertise
- c) Complete control over data
- d) Simplified compliance

Answer: b) Increased physical security and expertise

Explanation: Major cloud providers invest heavily in state-of-the-art physical security measures (biometrics, surveillance, guards) and employ dedicated security experts, which is often beyond the budget of a single company.

2. The "Shared Responsibility Model" in cloud security means:

- a) The provider and customer share the cost of security breaches.
- b) Security is always the primary responsibility of the provider.
- c) Security responsibilities are divided between the provider and the customer.
- d) The customer is responsible for all security aspects.

Answer: c) Security responsibilities are divided between the provider and the customer.

Explanation: The model defines what the cloud provider is responsible for (security of the cloud) and what the customer is responsible for (security in the cloud).

3. Which cloud service model gives the customer the MOST control over security configurations?

- a) Software as a Service (SaaS)
- b) Platform as a Service (PaaS)
- c) Infrastructure as a Service (IaaS)
- d) Security as a Service (SECaaS)

Answer: c) Infrastructure as a Service (IaaS)

Explanation: In IaaS, the customer manages the operating systems, applications, and network configurations, giving them the most control over the security settings of their environment.



4. Which of the following is a key benefit of cloud computing?

- a) Guaranteed 100% uptime
- b) Elimination of all security risks
- c) Rapid elasticity and scalability
- d) Reduced need for internet connectivity

Answer: c) Rapid elasticity and scalability

Explanation: Cloud resources can be scaled up or down quickly to meet demand, which is a fundamental characteristic of cloud computing.

5. What does the term "Multi-tenancy" mean in cloud computing?

- a) A single application serving multiple customers
- b) Multiple customers using separate, isolated resources
- c) Multiple customers sharing the same physical resources
- d) A customer using services from multiple providers

Answer: c) Multiple customers sharing the same physical resources

Explanation: Multi-tenancy is an architecture where a single instance of software and its underlying infrastructure serves multiple customers ("tenants").

6. Which type of cloud deployment model offers the highest level of control and security?

- a) Public Cloud

- b) Hybrid Cloud
- c) Community Cloud
- d) Private Cloud

Answer: d) Private Cloud

Explanation: A private cloud is operated solely for a single organization, offering the greatest level of control, customization, and isolation, which can enhance security.

7. What is the purpose of data encryption "at rest"?

- a) To protect data while it is being transmitted over a network
- b) To protect data while it is stored on a disk or database
- c) To prevent data from being deleted
- d) To compress data to save space

Answer: b) To protect data while it is stored on a disk or database

Explanation: Encryption at rest ensures that stored data is unreadable without the decryption keys, protecting it from physical theft or unauthorized access.

8. Which tool is commonly used to define and enforce security policies across cloud resources?

- a) Cloud Access Security Broker (CASB)
- b) Intrusion Detection System (IDS)
- c) Virtual Private Network (VPN)
- d) Web Application Firewall (WAF)

Answer: a) Cloud Access Security Broker (CASB)

Explanation: A CASB is a security policy enforcement point that sits between cloud service consumers and providers to enforce security, compliance, and governance policies.

9. A DDoS (Distributed Denial of Service) attack primarily aims to:

- a) Steal sensitive customer data
- b) Encrypt files for ransom
- c) Overwhelm a system with traffic to make it unavailable
- d) Gain administrative access to servers

Answer: c) Overwhelm a system with traffic to make it unavailable

Explanation: A DDoS attack floods a target's resources (e.g., servers, network) with massive traffic from multiple sources, rendering them unable to serve legitimate users.

10. Identity and Access Management (IAM) is crucial in the cloud for:

- a) Ensuring high-speed data transfer
- b) Managing user identities and controlling their access to resources
- c) Encrypting all database contents
- d) Providing automatic backups

Answer: b) Managing user identities and controlling their access to resources

Explanation: IAM systems ensure that the right individuals (identities) access the right resources at the right times for the right reasons.

11. What is a "security group" in Amazon Web Services (AWS)?

- a) A team of security engineers
- b) A virtual firewall for EC2 instances to control inbound and outbound traffic
- c) A method for grouping security alerts
- d) A encrypted storage volume

Answer: b) A virtual firewall for EC2 instances to control inbound and outbound traffic

Explanation: In AWS, security groups act as stateful virtual firewalls that control traffic to and from Amazon EC2 instances.

12. The principle of "Least Privilege" means:

- a) Users should have their accounts permanently privileged.
- b) Users should be granted the minimum levels of access necessary to perform their duties.
- c) Privileged accounts should be used for all tasks.
- d) All users should have administrative access.

Answer: b) Users should be granted the minimum levels of access necessary to perform their duties.

Explanation: This principle reduces the attack surface by limiting the potential damage from a compromised account or user error.

13. Which compliance standard is specifically designed for the payment card industry?

- a) HIPAA
- b) GDPR
- c) PCI DSS
- d) SOX

Answer: c) PCI DSS

Explanation: The Payment Card Industry Data Security Standard (PCI DSS) is a set of security standards designed to ensure that all companies that process, store, or transmit credit card information maintain a secure environment.

14. What is a major security concern with serverless computing (e.g., AWS Lambda)?

- a) Physical server security
- b) Managing the operating system
- c) Insecure third-party dependencies and event data injection
- d) Configuring virtual networks



Answer: c) Insecure third-party dependencies and event data injection

Explanation: While the provider manages the OS and infrastructure, the customer is responsible for the function code and its dependencies, which can introduce vulnerabilities like code injection attacks.

15. Penetration Testing in the cloud:

- a) Is never allowed by cloud providers.
- b) Can usually be performed without provider approval on any service.
- c) Often requires explicit permission from the cloud provider.
- d) Is the sole responsibility of the provider.

Answer: c) Often requires explicit permission from the cloud provider.

Explanation: Cloud providers have acceptable use policies. Conducting simulated attacks (pen testing) without prior authorization may be mistaken for a real attack and violate terms of service.

16. Which service provides a secure, private connection between an on-premises network and a VPC in the cloud?

- a) Content Delivery Network (CDN)
- b) Virtual Private Network (VPN)
- c) Domain Name System (DNS)
- d) Load Balancer

Answer: b) Virtual Private Network (VPN)

Explanation: A VPN creates an encrypted tunnel over the public internet to connect a company's on-premises data center or network to its cloud VPC.

17. What is the main goal of data masking or tokenization?

- a) To improve database performance
- b) To reduce storage costs
- c) To de-identify sensitive data in non-production environments
- d) To encrypt data for transmission

Answer: c) To de-identify sensitive data in non-production environments

Explanation: Data masking replaces sensitive data with realistic but fictional data, allowing developers and testers to use datasets without exposing real personal information.

18. A vulnerability that allows a user to access resources from another tenant in a cloud environment is a:

- a) Data Breach
- b) Isolation Failure
- c) DDoS Attack
- d) Insider Threat

Answer: b) Isolation Failure

Explanation: This refers to a failure in the hypervisor or cloud management platform that is supposed to keep tenant environments strictly separated from one another.

19. What does a Web Application Firewall (WAF) protect against?

- a) Phishing emails
- b) Common web exploits like SQL injection and cross-site scripting (XSS)
- c) Insider data theft
- d) Physical intrusion

Answer: b) Common web exploits like SQL injection and cross-site scripting (XSS)

Explanation: A WAF is designed to monitor, filter, and block HTTP traffic to and from a web application, specifically targeting attacks like SQLi, XSS, and file inclusion.

20. Which of these is a characteristic of a well-designed cloud disaster recovery (DR) plan?

- a) It relies on manual processes for consistency.
- b) Its Recovery Time Objective (RTO) is as long as possible.
- c) It is tested regularly.
- d) It stores backups only in the same region as the primary data.

Answer: c) It is tested regularly.

Explanation: A DR plan is useless if it doesn't work when needed. Regular testing ensures the plan is effective and the team is familiar with the procedures.

21. The EU's General Data Protection Regulation (GDPR) is primarily concerned with:

- a) Regulating financial markets
- b) Protecting the personal data and privacy of EU citizens
- c) Standardizing encryption algorithms
- d) Controlling cloud provider pricing

Answer: b) Protecting the personal data and privacy of EU citizens

Explanation: GDPR imposes strict rules on data controllers and processors anywhere in the world if they handle the personal data of individuals in the European Union.

22. What is the main purpose of a Cloud Security Posture Management (CSPM) tool?

- a) To encrypt all data at rest
- b) To automatically detect and remediate misconfigurations
- c) To provide anti-virus for virtual machines

d) To manage user identities

Answer: b) To automatically detect and remediate misconfigurations

Explanation: CSPM tools continuously monitor cloud environments for misconfigured resources (e.g., open S3 buckets, weak security group rules) that pose security risks.

23. Which of the following is an example of an "insider threat"?

- a) A hacker from a foreign country
- b) A disgruntled employee with authorized access
- c) A natural disaster
- d) A hardware failure

Answer: b) A disgruntled employee with authorized access

Explanation: An insider threat is a security risk that originates from within the organization, often from employees, contractors, or business partners.

24. What does "Data Residency" refer to?

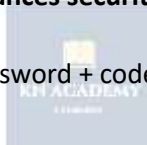
- a) The speed at which data can be accessed
- b) The physical geographic location where data is stored
- c) The cost of storing data
- d) The process of archiving old data

Answer: b) The physical geographic location where data is stored

Explanation: Data residency is concerned with the legal and regulatory requirements mandating that data be stored and processed in a specific country or region.

25. MFA (Multi-Factor Authentication) enhances security by requiring:

- a) Multiple passwords
- b) Two or more verification factors (e.g., password + code from phone)
- c) Biometric verification only
- d) Automatic logouts after inactivity



Answer: b) Two or more verification factors (e.g., password + code from phone)

Explanation: MFA requires two or more independent credentials: what you know (password), what you have (security token), and/or what you are (biometric).

26. Which cloud deployment model combines on-premises infrastructure with public cloud services?

- a) Public Cloud
- b) Private Cloud
- c) Hybrid Cloud
- d) Multi-Cloud

Answer: c) Hybrid Cloud

Explanation: A hybrid cloud blends a private cloud (on-premises) and a public cloud, with orchestration between the two platforms.

27. What is the primary risk of using shadow IT?

- a) Increased cost
- b) It bypasses organizational security policies and controls
- c) It slows down innovation
- d) It requires more IT staff

Answer: b) It bypasses organizational security policies and controls

Explanation: Shadow IT refers to IT systems and solutions used without explicit organizational approval, making them invisible to and unmanaged by the security team.

28. An API (Application Programming Interface) gateway in a cloud environment can enhance security by:

- a) Providing physical security for servers
- b) Acting as a single entry point to manage, authenticate, and throttle API traffic
- c) Encrypting all data at rest automatically
- d) Replacing the need for a firewall

Answer: b) Acting as a single entry point to manage, authenticate, and throttle API traffic

Explanation: An API gateway is a management tool that sits between clients and backend services, providing authentication, rate limiting, and monitoring for APIs.

29. What is the main purpose of a Business Continuity Plan (BCP)?

- a) To ensure only authorized users have access
- b) To maintain essential functions during and after a disaster
- c) To encrypt all customer data
- d) To reduce cloud spending

Answer: b) To maintain essential functions during and after a disaster

Explanation: A BCP is a broader plan than DR; it focuses on maintaining business operations, including processes, assets, human resources, and more.

30. Which storage class in cloud storage (e.g., Amazon S3) is designed for long-term archival with the lowest cost?

- a) Standard
- b) Infrequent Access
- c) Glacier/Deep Archive
- d) One Zone-Infrequent Access

Answer: c) Glacier/Deep Archive

Explanation: Archive storage classes like Amazon S3 Glacier or Deep Archive are optimized for data that is rarely accessed and has retrieval times of several hours, at the lowest cost.



31. Container security best practices include:

- a) Always running containers as the root user
- b) Using only the latest image tags without scanning
- c) Scanning images for vulnerabilities and running with least privilege
- d) Storing secrets and API keys within the container image

Answer: c) Scanning images for vulnerabilities and running with least privilege

Explanation: Containers should be built from secure base images, scanned for vulnerabilities, and configured to run with non-root users and minimal necessary privileges.

32. What does a Content Delivery Network (CDN) primarily improve?

- a) Data encryption strength
- b) Performance and availability by caching content at edge locations
- c) Physical security of data centers
- d) User access control policies

Answer: b) Performance and availability by caching content at edge locations

Explanation: A CDN distributes content to servers around the world (edge locations), reducing latency for end users and providing DDoS mitigation benefits.

33. The term "Zero Trust" security model is based on the concept of:

- a) "Trust no one, verify everything"
- b) "Trust but verify"

- c) "Implicit trust within the corporate network"
- d) "Complete trust in the cloud provider"

Answer: a) "Trust no one, verify everything"

Explanation: The Zero Trust model assumes no implicit trust is granted to assets or user accounts based solely on their physical or network location.

34. Which type of encryption key is managed by the cloud provider?

- a) Customer-Managed Key (CMK)
- b) Provider-Managed Key (PMK)
- c) Bring Your Own Key (BYOK)
- d) Hardware Security Module (HSM)

Answer: b) Provider-Managed Key (PMK)

Explanation: With provider-managed keys, the cloud service provider handles the entire lifecycle and management of the encryption keys.

35. What is the primary function of an Intrusion Detection System (IDS)?

- a) To block malicious traffic automatically
- b) To monitor network traffic and generate alerts for suspicious activity
- c) To encrypt all data packets
- d) To authenticate users

Answer: b) To monitor network traffic and generate alerts for suspicious activity

Explanation: An IDS is a monitoring system that detects and alerts on potential violations but typically does not take action to block them (that's an IPS - Intrusion Prevention System).

36. A security misconfiguration is most likely to lead to:

- a) Improved performance
- b) A data breach
- c) Lower costs
- d) Faster deployment

Answer: b) A data breach

Explanation: Misconfigurations (e.g., unsecured storage buckets, default passwords) are a leading cause of data breaches in the cloud.



37. What is the purpose of a Service Level Agreement (SLA) in cloud computing?

- a) To define the price of services
- b) To legally define the service standards, including uptime and support responsiveness
- c) To specify the technical architecture
- d) To list all employees of the provider

Answer: b) To legally define the service standards, including uptime and support responsiveness

Explanation: An SLA is a contract that formally defines the performance and reliability standards a provider agrees to meet.

38. Which strategy involves using multiple cloud providers to avoid vendor lock-in and increase resilience?

- a) Hybrid Cloud
- b) Private Cloud
- c) Multi-Cloud
- d) Community Cloud

Answer: c) Multi-Cloud

Explanation: A multi-cloud strategy involves using services from multiple cloud providers (e.g., AWS and Azure) for the same purpose.

39. What is a "cold" disaster recovery site?

- a) A site with running servers that can take over immediately
- b) A site with power and cooling but no pre-configured hardware
- c) A cloud-based recovery site
- d) A site located in a cold climate for natural cooling

Answer: b) A site with power and cooling but no pre-configured hardware

Explanation: A cold site has the basic infrastructure but requires hardware to be shipped, set up, and configured after a disaster, leading to the longest recovery time.

40. Which regulation governs the protection of health information in the United States?

- a) GDPR
- b) PCI DSS
- c) HIPAA
- d) FISMA

Answer: c) HIPAA

Explanation: The Health Insurance Portability and Accountability Act (HIPAA) sets the standard for protecting sensitive patient data.

41. The "CIA Triad" in security stands for:

- a) Central Intelligence Agency
- b) Confidentiality, Integrity, Availability
- c) Cloud Infrastructure Access
- d) Critical Incident Analysis



Answer: b) Confidentiality, Integrity, Availability

Explanation: This is a fundamental security model: Confidentiality (data is secret), Integrity (data is accurate and untampered), Availability (data is accessible when needed).

42. What is the main security risk of using public container images from registries like Docker Hub?

- a) They are always more expensive.
- b) They may contain malicious code or vulnerabilities.
- c) They cannot be scaled.
- d) They are always slower.

Answer: b) They may contain malicious code or vulnerabilities.

Explanation: Public images can be outdated or maliciously modified. It's crucial to scan them and use trusted sources.

43. What does "VPC" stand for in cloud networking?

- a) Virtual Public Connection
- b) Verified Private Cloud
- c) Virtual Private Cloud
- d) Virtual Packet Circuit

Answer: c) Virtual Private Cloud

Explanation: A VPC is an isolated, logically defined section of a public cloud where you can launch resources in a virtual network you define.

44. Which of these is a database security best practice?

- a) Use default database passwords for simplicity.

- b) Enable public access to the database for easy connectivity.
- c) Use parameterized queries to prevent SQL injection.
- d) Store database logs in the same instance as the database.

Answer: c) Use parameterized queries to prevent SQL injection.

Explanation: Parameterized queries ensure that user input is treated as data, not executable code, which is the primary defense against SQL injection attacks.

45. A security audit is performed primarily to:

- a) Improve system performance
- b) Reduce storage costs
- c) Verify compliance with security policies and regulations
- d) Develop new software features

Answer: c) Verify compliance with security policies and regulations

Explanation: Audits are systematic evaluations to determine if a system is adhering to established security policies, standards, and regulatory requirements.

46. What is the key difference between a vulnerability and an exploit?

- a) A vulnerability is a weakness; an exploit is code that attacks it.
- b) They are the same thing.
- c) An exploit is a weakness; a vulnerability is an attack.
- d) A vulnerability is always more dangerous.

Answer: a) A vulnerability is a weakness; an exploit is code that attacks it.

Explanation: A vulnerability is a flaw or weakness in a system. An exploit is a piece of software or a technique that takes advantage of that vulnerability to cause unintended behavior.

47. Which service provides secrets management (e.g., for API keys, passwords) in AWS?

- a) AWS Secrets Manager
- b) AWS IAM
- c) AWS KMS
- d) AWS CloudTrail

Answer: a) AWS Secrets Manager

Explanation: AWS Secrets Manager is specifically designed to rotate, manage, and retrieve secrets like database credentials and API keys throughout their lifecycle.

48. What is the primary purpose of log management and monitoring?

- a) To use more storage space
- b) To enable forensic analysis and detect anomalies in real-time
- c) To slow down applications
- d) To comply with data residency laws

Answer: b) To enable forensic analysis and detect anomalies in real-time

Explanation: Centralized logging and monitoring allow security teams to investigate past incidents (forensics) and identify suspicious activity as it happens.

49. What does "Immutable Infrastructure" refer to?

- a) Infrastructure that cannot be changed
- b) Servers that are never patched or updated
- c) An approach where servers are never modified after deployment; instead, they are replaced with new versions
- d) Infrastructure located in a single data center

Answer: c) An approach where servers are never modified after deployment; instead, they are

replaced with new versions

Explanation: This practice enhances security and consistency. If a server is compromised, it is simply destroyed and replaced with a known-good image.

50. Which cloud-native tool in AWS provides a history of API calls and resource changes for auditing?

- a) AWS CloudWatch
- b) AWS Config
- c) AWS CloudTrail
- d) AWS Shield

Answer: b) AWS Config

Explanation: While CloudTrail logs API calls, AWS Config records configuration changes to resources, allowing you to assess compliance and audit changes over time. (Note: This is a tricky one. CloudTrail is for API activity auditing, while AWS Config is for resource configuration history and compliance auditing. Both are critical for security.)

51. What is the primary purpose of a "Bastion Host" (or Jump Box) in cloud architecture?

- a) To serve public web content
- b) To provide a single, secured entry point for administrative access to a private network
- c) To act as a primary database server
- d) To perform automated backups

Answer: b) To provide a single, secured entry point for administrative access to a private network

Explanation: A bastion host is a specially hardened server designed to withstand attacks. It is the only node exposed to the public internet, through which administrators SSH or RDP to access the internal private network.

52. Which AWS service provides protection against DDoS attacks?

- a) AWS GuardDuty
- b) AWS Shield
- c) AWS WAF
- d) AWS KMS

Answer: b) AWS Shield

Explanation: AWS Shield is a managed Distributed Denial of Service (DDoS) protection service that safeguards applications running on AWS.

53. The practice of "Server Hardening" involves:

- a) Making servers physically difficult to move
- b) Reducing server performance to save energy
- c) Reducing the attack surface by minimizing vulnerabilities
- d) Using only the most expensive server types

Answer: c) Reducing the attack surface by minimizing vulnerabilities

Explanation: Server hardening is the process of securing a server by removing unnecessary software, disabling unused services, and configuring the OS and applications securely.

54. What is a "Canary" in the context of security?

- a) A type of encryption algorithm
- b) A decoy system or piece of data designed to lure attackers and alert defenders
- c) A bird used to detect poisonous gases in data centers

d) A high-speed network connection

Answer: b) A decoy system or piece of data designed to lure attackers and alert defenders

Explanation: A canary (or honeypot) is a trap. Access to it is always unauthorized, so any access attempt triggers an immediate alert, indicating a breach.

55. Which of the following is a key principle of DevSecOps?

- a) Security is the sole responsibility of a separate team.
- b) Security testing is performed only after development is complete.
- c) Security is integrated into every phase of the software development lifecycle.
- d) Development speed is prioritized over security.

Answer: c) Security is integrated into every phase of the software development lifecycle.

Explanation: DevSecOps aims to "shift security left," meaning security considerations (like code analysis, vulnerability scanning) are integrated from the initial design through to development, deployment, and operation.

56. What does "Data Exfiltration" mean?

- a) The process of backing up data
- b) The unauthorized transfer of data from a system
- c) The encryption of data
- d) The process of importing data into a cloud environment

Answer: b) The unauthorized transfer of data from a system

Explanation: Data exfiltration is the unauthorized copying, transfer, or retrieval of data from a computer or server, often by an attacker.

57. Which Microsoft Azure service provides a single dashboard for managing security posture and threat protection?

- a) Azure Security Center
- b) Azure Active Directory
- c) Azure Sentinel
- d) Azure Policy



Answer: a) Azure Security Center (Now part of Microsoft Defender for Cloud)

Explanation: Azure Security Center (now unified under Microsoft Defender for Cloud) provides unified security management and advanced threat protection across hybrid cloud workloads.

58. What is the main security benefit of using "Microsegmentation"?

- a) To improve network speed
- b) To create security policies down to the workload level, limiting lateral movement
- c) To reduce the cost of firewalls
- d) To simplify network architecture

Answer: b) To create security policies down to the workload level, limiting lateral movement

Explanation: Microsegmentation involves defining fine-grained security policies for individual workloads, so if one is compromised, the attacker cannot easily move laterally to others.

59. In the context of incident response, what does "Containment" involve?

- a) Identifying the root cause of the incident
- b) Isolating the affected systems to prevent further damage
- c) Notifying customers and regulators
- d) Restoring systems from backup

Answer: b) Isolating the affected systems to prevent further damage

Explanation: Containment is the crucial step of limiting the scope and impact of a security incident by disconnecting, isolating, or shutting down affected systems.

60. Which type of security testing involves analyzing an application's source code for vulnerabilities?

- a) Penetration Testing
- b) Static Application Security Testing (SAST)
- c) Dynamic Application Security Testing (DAST)
- d) Vulnerability Scanning

Answer: b) Static Application Security Testing (SAST)

Explanation: SAST is a white-box testing method that analyzes an application's source code, bytecode, or binary code for vulnerabilities without actually executing the program.

61. What is the primary function of a Hardware Security Module (HSM)?

- a) To provide physical cooling for servers
- b) To securely generate, store, and manage cryptographic keys
- c) To act as a high-speed router
- d) To host virtual machines

Answer: b) To securely generate, store, and manage cryptographic keys

Explanation: HSMs are physical computing devices that safeguard and manage digital keys. They provide a highly secure environment for cryptographic operations.

62. The "Right to be Forgotten" is a key principle of which regulation?

- a) PCI DSS
- b) HIPAA
- c) GDPR
- d) SOX



Answer: c) GDPR

Explanation: The EU's General Data Protection Regulation (GDPR) gives individuals the right to request the deletion or removal of their personal data when there is no compelling reason for its continued processing.

63. What is a "Threat Model"?

- a) A list of all past security incidents
- b) A proactive process to identify potential threats and vulnerabilities
- c) A type of virus
- d) A profile of a cybercriminal

Answer: b) A proactive process to identify potential threats and vulnerabilities

Explanation: Threat modeling is a structured process for identifying and prioritizing potential threats (e.g., STRIDE model) and defining countermeasures to mitigate them.

64. Which Google Cloud Platform (GCP) service is used for secrets management?

- a) Cloud KMS
- b) Cloud IAM
- c) Secret Manager
- d) Security Command Center

Answer: c) Secret Manager

Explanation: GCP's Secret Manager provides a secure and convenient method for storing API keys, passwords, certificates, and other sensitive data.

65. A "Supply Chain Attack" targets:

- a) A company's logistics and shipping software
- b) The software development tools or third-party dependencies used to build an application
- c) The power supply to a data center
- d) The network cables connecting servers

Answer: b) The software development tools or third-party dependencies used to build an application

Explanation: A supply chain attack compromises a system by infecting a legitimate, trusted component (like an open-source library or a compiler) before it is delivered to the end user.

66. What does a high "Recovery Time Objective (RTO)" indicate?

- a) The system can be recovered very quickly.
- b) The organization can tolerate a long downtime.
- c) Data loss will be minimal.
- d) The disaster recovery plan is excellent.

Answer: b) The organization can tolerate a long downtime.

Explanation: RTO is the target time within which a business process must be restored after a disaster. A high RTO means the business can function for a longer period without that process.

67. Which concept involves granting temporary, elevated permissions to a user to perform a specific task?

- a) Permanent Privilege
- b) Just-In-Time (JIT) Access
- c) Role-Based Access Control (RBAC)
- d) Multi-Factor Authentication (MFA)

Answer: b) Just-In-Time (JIT) Access

Explanation: JIT access is a security principle where privileges are granted for a short, limited time only when needed, rather than being permanently assigned, reducing the attack surface.



68. What is the main risk associated with "Orphaned Resources" in the cloud?

- a) They improve cost efficiency.
- b) They can be forgotten but still running, incurring costs and posing security risks.
- c) They automatically scale down.
- d) They are automatically secured by the provider.

Answer: b) They can be forgotten but still running, incurring costs and posing security risks.

Explanation: Orphaned resources (like unattached storage volumes or unused instances) are often overlooked, continue to accrue costs, and may contain sensitive data or misconfigurations.

69. Which service is used for auditing and tracking user activity and API usage in AWS?

- a) AWS CloudTrail
- b) AWS Config
- c) AWS CloudWatch
- d) AWS X-Ray

Answer: a) AWS CloudTrail

Explanation: AWS CloudTrail is a service that enables governance, compliance, and operational and risk auditing of your AWS account by logging all API calls.

70. "Defense in Depth" is a strategy that employs:

- a) A single, strong perimeter firewall
- b) Multiple layers of security controls

- c) Hiding the location of the servers
- d) Using only proprietary software

Answer: b) Multiple layers of security controls

Explanation: Defense in Depth is a layered approach to security. If one control fails, another steps in to thwart an attack. It includes physical, network, host, application, and data security controls.

71. What is the primary use case for a "Cold" storage class in cloud storage?

- a) Hosting live website content
- b) Storing data that is frequently accessed and modified
- c) Long-term archival of data that is rarely accessed
- d) Caching session data for web applications

Answer: c) Long-term archival of data that is rarely accessed

Explanation: Cold storage (e.g., Amazon S3 Glacier) is optimized for data that is accessed very infrequently, with retrieval times of several hours, and is the cheapest storage option.

72. Which tool would you use to assess your AWS environment against best practices for security and compliance?

- a) AWS Trusted Advisor
- b) AWS Pricing Calculator
- c) AWS Migration Hub
- d) AWS Snowball

Answer: a) AWS Trusted Advisor

Explanation: AWS Trusted Advisor provides real-time guidance to help you provision your resources following AWS best practices, including cost optimization, performance, security, and fault tolerance checks.



73. A "Man-in-the-Middle" (MitM) attack succeeds by:

- a) Overwhelming a server with requests
- b) Secretly relaying and possibly altering the communication between two parties
- c) Guessing a user's password
- d) Infecting a system with ransomware

Answer: b) Secretly relaying and possibly altering the communication between two parties

Explanation: In a MitM attack, the attacker intercepts and potentially manipulates the communication between two parties who believe they are directly communicating with each other.

74. What is the key characteristic of a "Non-repudiation" security service?

- a) Data is kept secret from unauthorized users.
- b) Data is not altered in transit.
- c) The sender of a message cannot later deny having sent it.
- d) Systems are available 24/7.

Answer: c) The sender of a message cannot later deny having sent it.

Explanation: Non-repudiation provides proof of the origin and integrity of data, often achieved through digital signatures, preventing a party from denying an action.

75. Which cloud deployment model is shared by several organizations with common concerns (e.g., mission, security needs)?

- a) Public Cloud
- b) Private Cloud
- c) Hybrid Cloud
- d) Community Cloud

Answer: d) Community Cloud

Explanation: A community cloud is shared by several organizations and supports a specific community that has shared concerns (e.g., security, compliance, jurisdiction).

76. What does "Tokenization" achieve for sensitive data like credit card numbers?

- a) It encrypts the data with a reversible algorithm.
- b) It replaces the sensitive data with a non-sensitive equivalent (a "token") that has no exploitable value.
- c) It compresses the data to save space.
- d) It permanently deletes the data.

Answer: b) It replaces the sensitive data with a non-sensitive equivalent (a "token") that has no exploitable value.

Explanation: Tokenization substitutes a sensitive data element with a non-sensitive token. The original data is stored in a secure token vault, and the token is used in systems, reducing risk.

77. Which component is essential for establishing a secure connection to a cloud VPC from a single computer?

- a) A Content Delivery Network (CDN)
- b) A Client VPN
- c) A Load Balancer
- d) A Bastion Host

Answer: b) A Client VPN

Explanation: A Client VPN (like AWS Client VPN) allows individual users to securely connect their devices to the cloud network as if they were on a private network.

78. The "OWASP Top 10" is a list of the most critical:

- a) Cloud providers
- b) Web application security risks
- c) Encryption algorithms
- d) Compliance standards



Answer: b) Web application security risks

Explanation: The OWASP Top 10 is a standard awareness document for developers and web application security. It represents a broad consensus about the most critical security risks to web applications.

79. What is the primary purpose of a "Synchronization" attack against cloud data?

- a) To ensure data is consistent across devices
- b) To overwhelm a system by forcing it to resync data repeatedly
- c) To improve data availability
- d) To encrypt data for backup

Answer: b) To overwhelm a system by forcing it to resync data repeatedly

Explanation: This is a potential attack vector where an attacker triggers massive data synchronization requests to consume resources and cause a denial of service.

80. Which practice involves comparing current cloud configurations against a known secure baseline?

- a) Penetration Testing
- b) Benchmarking
- c) Vulnerability Scanning
- d) Secret Management

Answer: b) Benchmarking

Explanation: Security benchmarking involves comparing your system's configurations (e.g., CIS Benchmarks) against industry best practices and standards to identify deviations.

81. A "Worm" is a type of malware that is characterized by:

- a) Locking files and demanding a ransom
- b) Spying on user keystrokes
- c) Self-replicating and spreading to other systems without user intervention
- d) Displaying unwanted advertisements

Answer: c) Self-replicating and spreading to other systems without user intervention

Explanation: A worm is a standalone malware program that replicates itself to spread to other computers, often exploiting network vulnerabilities.

82. What is the main security concern with "Server-Side Request Forgery" (SSRF)?

- a) Forging a user's identity
- b) Tricking a server into making requests to internal resources that it should not have access to
- c) Stealing a user's session cookie
- d) Injecting malicious SQL code

Answer: b) Tricking a server into making requests to internal resources that it should not have access to

Explanation: In an SSRF attack, an attacker abuses a server's functionality to read or update internal resources. The server is tricked into contacting internal services that are otherwise protected by the firewall.

83. Which Azure service is a cloud-native SIEM (Security Information and Event Management) system?

- a) Azure Security Center
- b) Azure Sentinel
- c) Azure Monitor
- d) Azure Active Directory

Answer: b) Azure Sentinel

Explanation: Azure Sentinel is a scalable, cloud-native SIEM and SOAR (Security Orchestration Automated Response) solution.



84. The concept of "Data Sovereignty" is closely related to:

- a) Data portability
- b) Data residing in a country subject to its laws and governance structures
- c) Data encryption
- d) Data processing speed

Answer: b) Data residing in a country subject to its laws and governance structures

Explanation: Data sovereignty refers to the concept that digital data is subject to the laws of the country in which it is located or processed.

85. What is a "VPC Flow Log" in AWS used for?

- a) To encrypt traffic within a VPC
- b) To capture information about the IP traffic going to and from network interfaces
- c) To automatically scale network bandwidth
- d) To create a VPN connection

Answer: b) To capture information about the IP traffic going to and from network interfaces

Explanation: VPC Flow Logs capture metadata about the IP traffic (accepted/rejected, source, destination, etc.) and are used for troubleshooting and security monitoring.

86. Which of these is a key benefit of using "Infrastructure as Code" (IaC) for security?

- a) It eliminates the need for security policies.
- b) It allows security and compliance rules to be defined, version-controlled, and consistently applied.
- c) It makes infrastructure changes slower and more deliberate.
- d) It requires manual configuration for each deployment.

Answer: b) It allows security and compliance rules to be defined, version-controlled, and consistently applied.

Explanation: With IaC (e.g., Terraform, AWS CloudFormation), security configurations are codified. This ensures environments are deployed identically and securely every time, and changes are auditable.

87. A "Blue/Green Deployment" strategy enhances security and availability by:

- a) Using two different cloud providers simultaneously
- b) Running two identical production environments and switching traffic at once
- c) Deploying code only on weekends
- d) Using only blue and green servers for branding

Answer: b) Running two identical production environments and switching traffic at once

Explanation: In blue/green deployment, the old version (blue) and new version (green) run in separate but identical environments. This allows for instant rollback if the new version has a security flaw or bug.

88. What is the primary purpose of a "Honeypot"?

- a) To store sweet data
- b) To attract and analyze attacker behavior in a controlled environment
- c) To improve application performance
- d) To serve as a primary production server

Answer: b) To attract and analyze attacker behavior in a controlled environment

Explanation: A honeypot is a decoy system designed to lure cyberattackers. It allows security researchers to study attack methods and gather intelligence.

89. Which type of access control model uses labels like "Confidential" and "Top Secret"?

- a) Role-Based Access Control (RBAC)
- b) Mandatory Access Control (MAC)
- c) Discretionary Access Control (DAC)
- d) Attribute-Based Access Control (ABAC)

Answer: b) Mandatory Access Control (MAC)

Explanation: In MAC, access rights are assigned by a central authority based on multiple levels of security (labels). Users cannot override policies set by the system.

90. What does the "Principle of Fail-Secure" state?

- a) Systems should fail open to maintain availability.
- b) Systems should fail in a way that protects security, even if it impacts availability.
- c) All failures should be logged but ignored.
- d) Failure is not an option.

Answer: b) Systems should fail in a way that protects security, even if it impacts availability.

Explanation: The fail-secure principle dictates that if a system fails, it should default to a secure state (e.g., a firewall failing to a "block all" state) rather than an insecure, permissive one.

91. A "Race Condition" vulnerability can be exploited by:

- a) Sending a very large amount of data
- b) Submitting requests at exactly the same time to exploit the time gap between check and use
- c) Phishing a user
- d) Brute-forcing a password

Answer: b) Submitting requests at exactly the same time to exploit the time gap between check and use

Explanation: A race condition occurs when the output of a process is unexpectedly dependent on the sequence or timing of other events. An attacker can exploit the tiny window between when a condition is checked and when it is used.

92. Which GCP service provides built-in DDoS protection and a global load balancer?

- a) Cloud CDN
- b) Cloud Armor
- c) Cloud NAT
- d) Cloud DNS

Answer: b) Cloud Armor

Explanation: Google Cloud Armor provides DDoS defense and WAF capabilities at the edge of Google's network, and it works with global load balancers.

93. What is "Vendor Lock-in" in the context of cloud computing?

- a) The physical locking of server racks
- b) The difficulty in moving from one cloud provider to another due to proprietary technologies
- c) A security feature that locks accounts
- d) A type of encryption provided by the vendor

Answer: b) The difficulty in moving from one cloud provider to another due to proprietary technologies

Explanation: Vendor lock-in occurs when a customer becomes dependent on a vendor's products and services and cannot easily switch to another vendor without substantial costs or technical challenges.

94. The "S3" in Amazon S3 stands for:

- a) Secure Storage Service
- b) Simple Storage Service
- c) System Storage Server
- d) Standard Storage System

Answer: b) Simple Storage Service

Explanation: Amazon S3 is Amazon's Simple Storage Service, an object storage service offering scalability, data availability, security, and performance.

95. Which security control is most effective against phishing attacks?

- a) Strong firewalls
- b) User security awareness training
- c) Intrusion Detection Systems (IDS)
- d) Using the latest antivirus software

Answer: b) User security awareness training

Explanation: Phishing attacks target humans. The most effective defense is training users to identify and report suspicious emails and links.

96. What is the main purpose of a "Service Control Policy" (SCP) in AWS Organizations?

- a) To control traffic between instances

- b) To define permission boundaries for what actions members accounts can do
- c) To encrypt data at rest
- d) To manage user passwords

Answer: b) To define permission boundaries for what actions members accounts can do

Explanation: SCPs are JSON policies that specify the maximum permissions for an organization or organizational unit (OU) in AWS Organizations. They act as a guardrail for what accounts can do.

97. A "Golden Image" is a:

- a) A specially colored server chassis
- b) A pre-configured, hardened, and approved virtual machine template used to launch new instances
- c) A backup of all data
- d) A certificate for SSL/TLS

Answer: b) A pre-configured, hardened, and approved virtual machine template used to launch new instances

Explanation: Using a golden image ensures that every new instance starts with a known, secure, and consistent configuration, compliant with organizational policies.

98. What does a "Secrets Manager" service help to prevent?

- a) Hardcoding API keys and passwords into application code
- b) Users from sharing passwords
- c) DDoS attacks
- d) Data loss due to hardware failure

Answer: a) Hardcoding API keys and passwords into application code

Explanation: A secrets manager (e.g., AWS Secrets Manager, Azure Key Vault) provides a secure way to store, rotate, and retrieve secrets programmatically, eliminating the need to store them in plaintext within code.

KN ACADEMY

99. Which metric measures the maximum tolerable amount of data loss after an incident?

- a) Recovery Time Objective (RTO)
- b) Recovery Point Objective (RPO)
- c) Mean Time To Recovery (MTTR)
- d) Service Level Agreement (SLA)

Answer: b) Recovery Point Objective (RPO)

Explanation: RPO is the maximum acceptable age of files that must be recovered from backup storage for normal operations to resume. It determines the frequency of backups (e.g., an RPO of 1 hour requires backups at least every hour).

100. The "Shared Responsibility Model" for IaaS states that the customer is responsible for:

- a) Physical security of the data centers
- b) Securing the hypervisor
- c) Securing the guest operating system and applications
- d) Controlling the network infrastructure

Answer: c) Securing the guest operating system and applications

Explanation: In the IaaS model, the cloud provider is responsible for security of the cloud (physical, hypervisor, network infrastructure). The customer is responsible for security in the cloud (guest OS, applications, data).